Hydra

Network Logon Cracking and Brute-Forcing

Hydra is a powerful, parallelized network logon cracker used by cybersecurity professionals to identify weak authentication mechanisms. Unlike offline cracking tools, Hydra performs **Online Brute-Force Attacks** by interacting directly with services in real-time. It supports a vast array of protocols, including **SSH**, **FTP**, and **HTTP Web Forms**.
This module introduces the core syntax for targeting various services, explains the logic of bypassing client-side filters using **Burp Suite** to capture request parameters, and provides practical walkthroughs for securing systems against credential-based attacks. Understanding Hydra is a foundational skill for aspiring SOC Analysts to monitor and defend against unauthorized access attempts.

This **documentation** and **learning** approach is strongly inspired by the structured, hands-on content provided by TryHackMe, which significantly contributed to practical understanding of "Hydra" concepts.

DOCUMENTED BY

Kaustubh Ghosalkar aka "WEIRDO"

LINKEDIN GITHUB

1. Introduction to Hydra

Hydra (specifically THC-Hydra) is a high-speed system login password "hacking" tool. It automates the process of guessing passwords by running through a wordlist against an authentication service.

- **Online vs. Offline:** Hydra is an **Online** cracker, meaning it requires an active connection to the target service (e.g., trying to log into a live website).
- **Protocol Support:** It supports over 50 protocols, including **Asterisk, FTP, HTTP-FORM-POST, IMAP, MySQL, RDP, SMB, SMTP, and SSH**.
- **Security Importance:** Hydra highlights the vulnerability of **Default Credentials** (e.g., admin:password) and common passwords.

2. Using Hydra for SSH Brute-Forcing

SSH (Secure Shell) is a common target for brute-force attacks. Hydra attempts to find a valid password for a specific user to gain remote command-line access.

SSH Command Breakdown

To attack SSH, use the following syntax:

```
hydra -l <username> -P <path_to_wordlist> <target_ip> -t 4 ssh
```

Option	Function	Description
-l	**Lowercase L**	Specifies a single **Username**.
-P	**Uppercase P**	Specifies the **Path** to the password wordlist.
-t	**Threads**	Sets the number of parallel connections (default is usually fine).
-V	**Verbose**	Displays every login attempt (useful for debugging).

Example: SSH Attack

Bash

```
hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.10.0.223 -t 4 ssh
```

- **Result:** This command will try every password in the rockyou.txt list for the user molly until the correct one is found.

WEIRDO

3. Attacking Web Login Forms

Web forms are more complex because they require specific parameters to identify how the website handles **HTTP POST** requests.

Syntax for Web Forms

```
hydra -l <username> -P <wordlist> <target_ip> http-post-form
"<path>:<parameters>:<failure_message>"
```

1. **Path:** The login page URL (e.g., /login).
2. **Parameters:** The form fields for username and password. Use **^USER^** and **^PASS^** as placeholders.
3. **Failure Message:** The text that appears when a login fails (e.g., "F=incorrect").

Example: Web Form Attack

Bash

```
hydra -l molly -P passwords.txt 10.10.124.12 http-post-form
"/login:username=^USER^&password=^PASS^:F=incorrect" -V
```

- **Analysis:** Hydra replaces ^USER^ with molly and ^PASS^ with words from the list. It knows a guess failed if the page returns the string "incorrect".

4. Attached YouTube Video Summary: Hydra Walkthrough (DarkStar7471)

The accompanying walkthrough video provides a step-by-step guide on using Hydra effectively within a TryHackMe environment.

- **Repertoire Essential:** Hydra is described as a core tool for any hacker's repertoire, specifically for forcing web logins.
- **Capturing Parameters:** The video demonstrates using **Burp Suite** to intercept a login request. This reveals exactly how the username and password variables are named in the **HTTP POST** body.
- **Identifying Failure:** To configure Hydra, you must manually fail a login to see the specific error message (e.g., "Your username or password is incorrect") used as the **Failure String**.
- **Thread Management:** The instructor notes that while Hydra defaults are usually optimal, you should lower the threads (-t) if the target server is slow or returning errors.
- **Wordlist Extraction:** A key tip is provided for Kali users: the **RockYou.txt** wordlist is often compressed by default and must be extracted using gunzip /usr/share/wordlists/rockyou.txt.gz before use.

WEIRDO

Conclusion and Cheatsheet

Conclusion

Hydra is the industry standard for network-based brute-forcing. Its flexibility across dozens of protocols makes it indispensable for testing authentication strength. However, users must be careful with **Threading** to avoid crashing target services. For Web Forms, tools like **Burp Suite** are necessary to identify the correct parameters. Always remember that **Complex Passwords** and **Account Lockout Policies** are the primary defenses against Hydra.

Fast Revision Cheatsheet

- **-l / -L:** Single User vs. User List.
- **-p / -P:** Single Password vs. Password List.
- **-t:** Threads (Speed). Lower this if you get errors.
- **-s:** Specify a non-default port (e.g., -s 2222).
- **-V:** Verbose mode to see every attempt.
- **^USER^ / ^PASS^:** Placeholders for web form data.
- **Failure Strings:** Start with F= to tell Hydra when a guess is wrong.
- **RockYou.txt:** The most common wordlist used for brute-forcing.

WEIRDO